

Information Assurance and Security: Foundations (Cornell Notes)

1. The McCumber Cube

Cues / Questions

- What is the McCumber Cube?
- What are the three information states?
- What does the CIA Triad stand for?
- How are countermeasures categorized?

Notes

- **Definition:** A 3D framework used to evaluate information system security by analyzing the interaction between three dimensions.
 - **Information States (Data Status):**
 - *Transmission (Data in Motion):* Data traveling over a network (e.g., sending an email).
 - *Storage (Data at Rest):* Data sitting on a hard drive or database.
 - *Processing (Data in Use):* Data currently being updated or calculated in RAM.
 - **Security Goals (The CIA Triad):**
 - *Confidentiality:* Protecting against unauthorized disclosure.
 - *Integrity:* Protecting against unauthorized modification.
 - *Availability:* Ensuring timely and reliable access.
 - **Countermeasures (Protection Methods):**
 - *Technology:* Hardware and software (e.g., Firewalls, Encryption).
 - *People:* Awareness, training, and ethics.
 - *Policies & Practices:* Standard Operating Procedures (SOPs), laws, and rules.
-

2. Foundations of Information Security (Functional Controls)

Cues / Questions

- How is security practically applied?
- What are the three main functional controls?

Notes

- **Prevention:** Stopping the attack before it happens (e.g., keeping an asset physically locked away).
 - **Detection:** Identifying that an attack is happening or has already happened (e.g., checking logs or using motion sensors).
 - **Mitigation (Response):** Limiting the damage once an incident is detected (e.g., reporting a loss or isolating a virus).
-

3. The AAA Framework

Cues / Questions

- What is the AAA Framework?
- What are the three authentication factors?
- Why is accounting important?

Notes

- **Authentication ("Who are you?"):** Proving identity.
 - *Factors:* Knowledge (Password), Possession (OTP/Token), Inherence (Biometrics).
 - **Authorization ("What are you allowed to do?"):** Defining permissions.
 - *Example:* A student can view their profile but cannot edit the grade database.
 - **Accounting / Auditing ("What did you do?"):** Tracking user actions.
 - *Non-repudiation:* Ensures a user cannot deny performing an action because the logs provide definitive proof.
-

4. Key Security Principles

Cues / Questions

- What are the core security principles?
- What is the difference between Least Privilege and Need-to-Know?
- What is Defense in Depth?
- Why is Open Design better than Security through Obscurity?

Notes

- **Least Privilege:** Give users only the minimum permissions necessary to perform their job.
 - **Need-to-Know:** Having clearance does not guarantee access; data is only accessible if required for the current task.
 - **Separation of Duties:** Splitting a sensitive task between two people to prevent fraud (e.g., one requests a check, another signs it).
 - **Defense in Depth:** Employing layered security (e.g., if a firewall fails, host-based antivirus serves as a backup).
 - **Fail Safe (Security by Default):** If a system crashes, it must fail into a "locked" state, not an "open" state.
 - **Security by Design:** Security is integrated into the software from the very first line of code, not added as an afterthought.
 - **Principle of Complete Mediation:** Every access to every object must be checked for authority (no shortcuts after the first login).
 - **Economy of Mechanism:** Keep security design simple and small to reduce the "attack surface".
 - **Open Design:** Security should not rely on the secrecy of the design (avoid "Security through Obscurity"). The system must remain secure even if an attacker knows how it works (e.g., AES encryption).
-

Summary

The foundations of Information Assurance and Security rely on structured frameworks and core principles to protect data. The McCumber Cube evaluates security across data states (Transmission, Storage, Processing), CIA goals (Confidentiality, Integrity, Availability), and countermeasures (Technology, People, Policies). Practical security is implemented through functional controls: Prevention, Detection, and Mitigation. User interactions are governed by the AAA framework (Authentication, Authorization, Accounting) to verify identity, manage permissions, and ensure non-repudiation. Furthermore, robust security architectures are guided by key principles such as Least Privilege, Defense in Depth, and Open Design to minimize vulnerabilities and maintain secure states.